

FIRST DRAFT -- NOT AN ATTESTATION

PCI DSS posture: The Train Station

This is a working draft for John (and later counsel / the acquirer). It is **not** a Self-Assessment Questionnaire, not an Attestation of Compliance, and not legal or QSA advice. The merchant of record is Jeremy's Train Station Stripe account. Volume is far below Level 1.

Recommended questionnaire if the current architecture holds: **SAQ A** (PCI DSS v4.0.1), because card data is collected on **Stripe-hosted Checkout** (redirect), not on thetrainstation.co forms. Stripe documents Checkout / Elements / Connect as SAQ A integrations.

1. Scope snapshot (as built 13 Sep 2026)

Item	Finding
Merchant	Jeremy Byrd / The Train Station -- Stripe LIVE master. John is not a second merchant.
Site	https://www.thetrainstation.co -- Next.js on Vercel. Postgres on Supabase (catalog).
Card collection	Stripe Checkout Session (hosted page). Member is redirected off-site. No card fields in our React tree.
CHD in our DB?	No PAN, expiry, or CVC columns. We store Stripe customer / subscription / checkout session IDs only.
Other money	Venmo QR + coach Mark paid (not card). Tips via Stripe Checkout. BYOW door is free (no payment).
Likely merchant level	Level 4 (well under 20k e-commerce tx / year). Acquirer has the final say.
Likely SAQ	SAQ A if we stay on hosted Checkout / no card fields on our origin.

2. What we do not do (eligibility for SAQ A)

SAQ A is for card-not-present merchants who fully outsource account-data handling to a PCI-validated provider and do not store, process, or transmit cardholder data on their own systems.

- No card number inputs on thetrainstation.co (no Stripe.js v2, no raw PaymentIntent card objects from our forms).
- Checkout is a Stripe-hosted URL from Checkout Sessions. Webhook receives events (customer, subscription, payment_intent ids) -- not PAN.
- Postgres MemberProfile keeps stripeCustomerId / stripeSubscriptionId / stripeCheckoutSessionId.
- BYOW (/byow) has no Stripe path. Free notes door. Out of CHD scope.
- Venmo is a separate rail (QR + Mark paid). Not card data.
- No card-present / Terminal / MOTO routine process.

3. What still has to be true (gaps for a real SAQ)

PCI DSS v4.0.1 SAQ A is short, but eligibility now includes confirming that payment pages are not susceptible to script attacks, and that payment-page content comes from the TPSP. Full redirect to Checkout is the cleaner story. Do not add Stripe Elements on our origin without revisiting SAQ A-EP.

Gap	Why it matters	Draft action
Stripe AOC on file	Must confirm TPSP is PCI compliant.	Download Stripe's current AoC; store with this draft.

Gap	Why it matters	Draft action
Acquirer / Stripe questionnaire	Stripe Risk Management may still ask Level 3/4 merchants to complete a form.	Complete Stripe's PCI form when prompted. Do not invent answers.
Payment-page scripts	If any page that starts Checkout loads third-party JS, document it.	Inventory scripts on /member/checkout and /join. Prefer redirect-only.
CSP / SRI	Good hygiene even if SAQ A no longer lists 6.4.3/11.6.1 as SAQ questions.	Tighten Content-Security-Policy on checkout routes.
ASV scan	Some acquirers still want quarterly scans even at Level 4.	Ask Stripe/bank if required. Do not skip if they say yes.
Access / logs	Who can see Stripe Dashboard and Vercel env.	Jeremy merchant; John admin. No PAN in logs (verify webhook logger).
Supabase Free	No vendor DB backups (separate from PCI).	Upgrade Pro \$25/mo for backups; CHD still must not be in DB.
Venmo Mark paid	Not card, but money movement.	Keep it coach-operated; do not collect card numbers in chat.

4. Code pointers (for counsel / a future QSA)

`/api/stripe/checkout` creates a Checkout Session and returns a Stripe URL. `/api/stripe/webhook` is the only inbound card-adjacent surface -- event JSON, no PAN. **MemberProfile** stores Stripe IDs. **completeMemberSignup** BYOW channel never calls Checkout. Do not add a card form to /byow or /member/checkout without a new SAQ review.

5. What this draft is not

It is not SAQ A filled out. It is not a ROC. It does not satisfy an acquirer by itself. John should not sign an Attestation until Stripe's current PCI form and (if required) an ASV scan are done. If we ever collect cards on our origin, this draft is void and the questionnaire becomes SAQ A-EP or D.

Prepared 13 Sep 2026 from the live architecture. Update when Checkout, Elements, Terminal, or a second merchant is added.